

Assessment

Tool - 3

Name : A. Sai Joshitha

Reg No : 192424220

course code : ITAI408

course Name : Ethical Hacking

During a coordinated disclosure process, the vendor asks you to delay public disclosure indefinitely with no fixed patch timeline, citing "business reasons" unrelated to the technical fix. As the researchers face, and how to mitigate how do you balance ethical disclosure obligations against vendor pressure?

When a security researcher discovers a vulnerability, they should first report it privately to the vendor through the coordinated vulnerability disclosure (CVD) process. This gives the vendor an opportunity to fix the problem before it is made public, helping to protect users from potential attacks.

If the vendor asks to delay public disclosure indefinitely for business reasons without providing a clear patch timeline, the researcher should balance cooperation with ethical responsibility.

Steps a Researcher should follow:

1. Report the vulnerability Responsibly

- Inform the vendor privately with complete technical details.
- Provide proof of the vulnerability and explain its impact.
- Give suggestions, if possible, for fixing the issue.

2. Give the vendor Reasonable Time

- Allow the vendor enough time to investigate and develop a security patch
- Be patient and cooperative during the fixing process
- Understand that complex vulnerabilities may require additional time

3. Request a clear Patch Timeline

- Ask the vendor to provide an expected date for releasing the fix
- Maintain regular communication to monitor progress
- Document all emails and discussions for future reference.

4. Do Not Accept Indefinite Delays

- If the vendor keeps postponing the disclosure without a valid technical reason, explain that user safety is the highest priority.
- Business reasons alone are not enough to justify delaying disclosure forever.

5. protect the users

- If there is no meaningful progress after a reasonable period, the researcher should consider

responsible public disclosure

- share only the information necessary to warn users and help them protect themselves.
- Avoid releasing exploit code or unnecessary technical details that attackers could misuse before a patch is available.

6. Follow Ethical and Professional standard

- Act honestly, fairly, and professionally throughout the process
- Follow responsible disclosure guidelines and respect applicable laws

- The goal is not to damage the vendor's reputation but to improve cybersecurity and protect users.

How to Balance Ethics and vendor pressure

A researcher should maintain a balance between:

- supporting the vendor by giving enough time to fix the problem.
- protecting user by ensuring the vulnerability is not hidden indefinitely.

If the vendor is actively working on a fix and communicates openly the researcher should cooperate

However, if the vendor refuses to fix the issue or delays only for business reasons, the researcher has an ethical responsibility to disclose the vulnerability responsibly after providing reasonable notice

Conclusion:

A security researcher should always prioritize public safety, transparency, and responsible disclosure over business pressure.

Giving the vendor reasonable time to release a patch is important, but indefinite delays without a valid technical reason are not ethical. Responsible disclosure protect users, encourages vendors to improve security, and helps create a safer digital environment for everyone.